

AWS WAF & SYSTEMS MANAGER

AWS Web Application Firewall (WAF)

Objective: The objective of this experiment is to learn how to create and configure an AWS Web Application Firewall (WAF) to protect web applications from common web attacks such as SQL Injection (SQLi), Cross-Site Scripting (XSS), and excessive requests (rate limiting). The experiment also demonstrates how to associate a Web ACL with an Application Load Balancer (ALB) and monitor web traffic.

Prerequisites

Before starting, ensure you have:

- AWS Account
- IAM User with Administrator Access (or WAF permissions)
- Existing Application Load Balancer (ALB) (*recommended*)
- Running EC2 instance behind the ALB (*optional for testing*)
- Internet connection

Step 1: Login to AWS Console

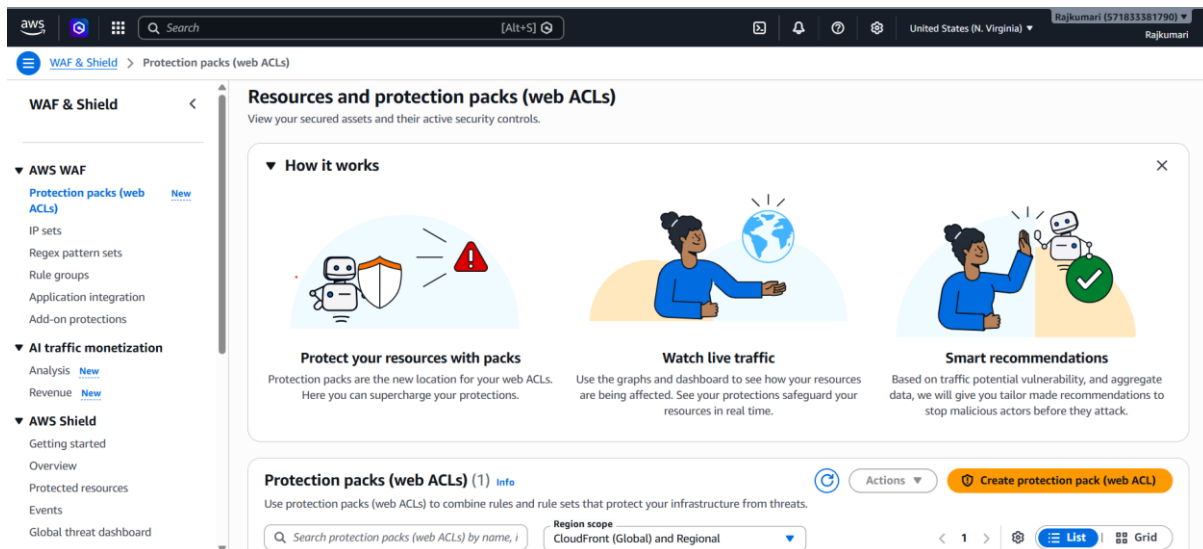
1. Open your browser.
2. Navigate to the AWS Management Console.
3. Sign in using your AWS credentials.

Expected Output: AWS Management Console Home page.

Step 2: Open AWS WAF

1. In the AWS search bar, type: WAF & Shield
2. Select **AWS WAF & Shield**.

Expected Output: AWS WAF Dashboard.



Step 3: Open Web ACLs

1. In the left navigation pane, click:

Web ACLs

2. Click:

Create Web ACL

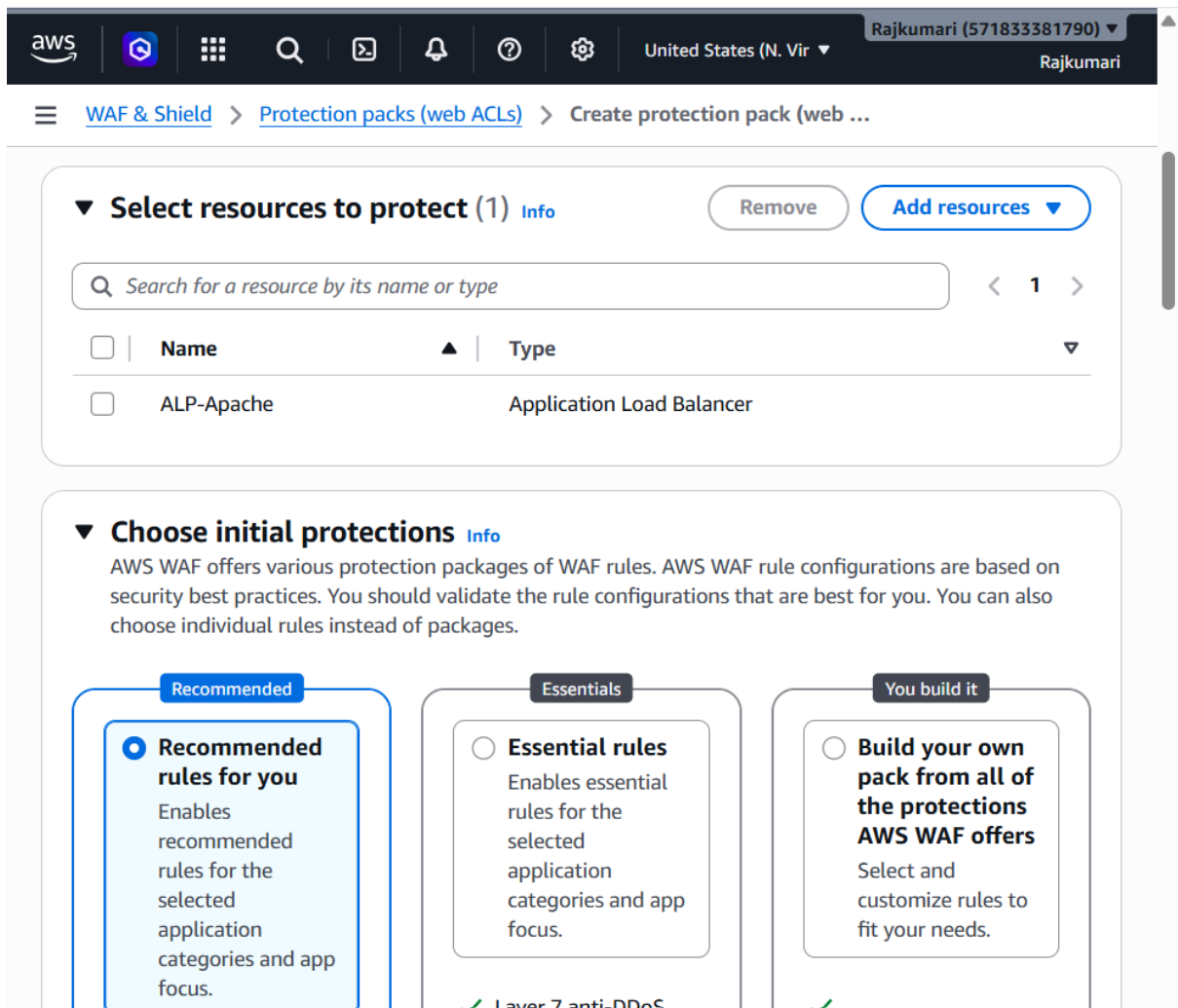
Expected Output: Create Web ACL page.

Step 4: Configure Web ACL

Enter the following details:

Field	Value
Name	Demo-WebACL
Description	Protect Demo Application
CloudWatch Metric Name	Demo-WebACL

Click **Next**.



Step 5: Configure Protection Pack Details

1. Name (Required)

Enter a unique name for your Web ACL.

Example: ALP-Apache-WAF

Note: The name cannot be changed after creation.

aws | United States (N. Vir) | Rajkumari (571833381790) | Rajkumari

WAF & Shield > Protection packs (web ACLs) > Create protection pack (web ...)

▼ Name and describe

Name
Used to identify this app protection and its CloudWatch metrics

ALP-Apache-WAF

Name **cannot** be changed later. Valid characters are letters, numbers, and hyphens (-).

Description - optional

Enter a description to help identify this protection pack (web ACL) later

The description can have up to 256 characters.

▼ Customize protection pack (web ACL) - optional [Info](#)

Default rule actions
Configure the default rule action which defaults to using both Count and Block actions based on the best practice configurations within the selected pack.

☒ **Use recommended defaults for Count and Block actions**
Sets all rules to use their recommended configurations.

☐ **Set all to Count action**
Test your rules in Count mode to evaluate their effectiveness before enabling Block mode. Count mode logs matching requests without blocking them.

Step 6: Configure Rate Limits

Objective: Configure a rate limit rule to restrict excessive requests from a single client IP address.

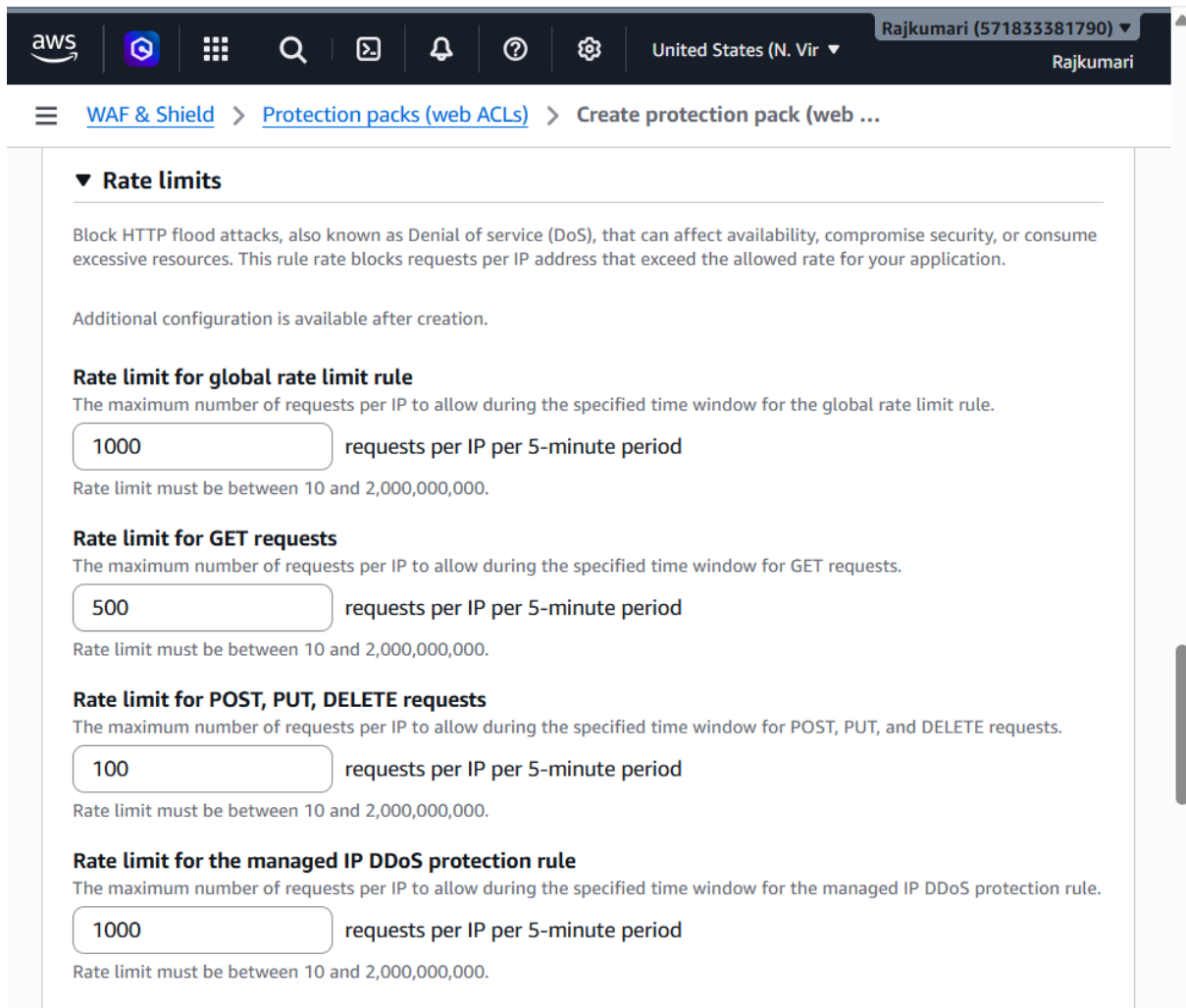
Procedure

1. On the **Create Protection Pack (Web ACL)** page, scroll to the **Rule configuration** section.
2. Click **Rate limits**.
3. Click **Add rate limit**.
4. Enter the required values:
 - **Rule Name:** RateLimitRule
 - **Request Limit:** 1000 requests
 - **Evaluation Window:** 5 Minutes

- **Action:** Block

5. Click **Save**.

Expected Result



aws | [Icons] | United States (N. Vir) | Rajkumari (571833381790) | Rajkumari

WAF & Shield > Protection packs (web ACLs) > Create protection pack (web ...)

▼ Rate limits

Block HTTP flood attacks, also known as Denial of service (DoS), that can affect availability, compromise security, or consume excessive resources. This rule rate blocks requests per IP address that exceed the allowed rate for your application.

Additional configuration is available after creation.

Rate limit for global rate limit rule
The maximum number of requests per IP to allow during the specified time window for the global rate limit rule.

requests per IP per 5-minute period

Rate limit must be between 10 and 2,000,000,000.

Rate limit for GET requests
The maximum number of requests per IP to allow during the specified time window for GET requests.

requests per IP per 5-minute period

Rate limit must be between 10 and 2,000,000,000.

Rate limit for POST, PUT, DELETE requests
The maximum number of requests per IP to allow during the specified time window for POST, PUT, and DELETE requests.

requests per IP per 5-minute period

Rate limit must be between 10 and 2,000,000,000.

Rate limit for the managed IP DDoS protection rule
The maximum number of requests per IP to allow during the specified time window for the managed IP DDoS protection rule.

requests per IP per 5-minute period

Rate limit must be between 10 and 2,000,000,000.

Step 7: Configure IP Addresses

Objective: Allow or block traffic from specific IP addresses.

Procedure

1. In the **Rule configuration** section, click **IP addresses**.
2. Click **Create IP Set**.
3. Enter:
 - **IP Set Name:** Office-IP-AllowList

- **IP Version:** IPv4
4. Add the required IP address.

Example:

203.0.113.10/32

5. Select the action:
 - **Allow** (recommended for trusted IPs)
 - **Block** (for unwanted IPs)
6. Click **Save**.

aws WAF & Shield > Protection packs (web ACLs) > Create protection pack (web ...)

▼ IP addresses

IP set for addresses to block
Use a stored IP set for consistent, reusable, and scalable IP-based security across multiple protection packs (web ACLs).

Create a new IP set ▼

IP addresses to block
Any IP address included will automatically be blocked, superseding other protection rules.

10.0.0.0/32, 2001:db8:a0b:12f0::1/128

Enter IP addresses separated by commas or new lines in CIDR format.

IP set for addresses to allow
Use a stored IP set for consistent, reusable, and scalable IP-based security across multiple protection packs (web ACLs).

Create a new IP set ▼

IP addresses to allow
Any IP address included will automatically be allowed, superseding other protection rules.

10.0.0.0/32, 2001:db8:a0b:12f0::1/128

Enter IP addresses separated by commas or new lines in CIDR format.

Step 8: Configure Countries

Objective: Restrict or allow access based on the client's geographic location.

Procedure

1. In the **Rule configuration** section, click **Countries**.
2. Click **Add Country Rule**.
3. Select the required action:
 - **Allow**
 - **Block**
4. Choose one or more countries.

Example:

- India
- United States

or

- China
- Russia

5. Click **Save**.

United States (N. Vir ▼
Rajkumari (571833381790) ▼
Rajkumari

WAF & Shield > Protection packs (web ACLs) > Create protection pack (web ...

▼ Countries

Action
Action to take when a request matches this protection.

Block ▼

Country codes
Default settings reflect commonly rate limited countries.

Choose country codes ▼

Cuba - CU ✕
Iran, Islamic Republic of - IR ✕

Korea, Democratic People's Republic of - KP ✕

Russian Federation - RU ✕
Syrian Arab Republic - SY ✕

Venezuela, Bolivarian Republic of - VE ✕

Logging destination [Info](#)
Where your logs will be stored for your rules.

Logging destination type

Amazon CloudWatch Logs ▼

Amazon CloudWatch Logs log group
Select a log group in your account that begins with 'aws-waf-logs-' or create one in the Amazon CloudWatch console. You

WAF & Shield > Protection packs (web ACLs) > CreatedByCloudFront-19c21954 > Dashboard

WAF & Shield

▼ AWS WAF
Protection packs (web ACLs) New
IP sets
Regex pattern sets
Rule groups
Application integration
Add-on protections

▼ AI traffic monetization
Analysis New
Revenue New

▼ AWS Shield
Getting started
Overview
Protected resources
Events
Global threat dashboard

CreatedByCloudFront-19c21954

[Edit protection pack \(web ACL\)](#)

▼ Add recommended rules based on your traffic insights (3) [info](#)

AWS Threat Intelligence monitors your previous 2 weeks of allowed traffic for vulnerabilities. Mitigate these by interacting with the specific traffic dimensions below to enable the recommended AWS Managed Rules.

Vulnerable application traffic

669 ▲

Allowed Bots traffic

656 ▲

Allowed Anonymous IP traffic

8 ▲

Allowed IP reputation traffic

Rule enabled in default mode

Allowed DDoS sources

0

CreatedByCloudFront-19c21954 ▼

Last 3 hours
Local time ▼

Actions = ALLOW, BLOCK, CAPTCHA, CHALLENGE, MONETIZE ✕
Traffic type = ALL ✕

Sampled requests

Step 9: Review Protection Pack Configuration

Objective: Review all the configured settings before creating the Protection Pack (Web ACL).

Procedure

1. Verify the following details:
 - Protection Pack Name
 - Protected Resource (ALP-Apache)
 - App Category
 - App Focus
 - Initial Protection (Recommended)
 - Default Rule Actions
 - Rate Limits (if configured)
 - IP Address Rules (if configured)
 - Country Rules (if configured)
 - Logging Configuration (if enabled)
2. Ensure all information is correct.

Step 10: Create Protection Pack (Web ACL)

Objective

Create the AWS WAF Protection Pack.

Procedure

1. Click **Create protection pack (Web ACL)**.
2. Wait for AWS to create the Protection Pack.
3. The creation process usually takes **1–2 minutes**.

Expected Result

The Protection Pack is created successfully.

Step 11: Verify the Protection Pack

Objective

Verify that the Protection Pack is active.

Procedure

1. Navigate to:

AWS WAF



Protection Packs (Web ACLs)

2. Open your Protection Pack.

Verify the following:

Property	Expected Value
Status	Active
Protected Resource	ALP-Apache
Rules	Enabled

Step 12: Verify Associated Resource

Objective

Confirm that the Application Load Balancer is protected by AWS WAF.

Procedure

1. Open the **Associated Resources** tab.
2. Verify that your **ALP-Apache** Application Load Balancer is listed.

Expected Result

The Application Load Balancer appears under the associated resources.

Step 13: View Rules

Objective

Verify the configured security rules.

Procedure

1. Open the **Rules** tab.
2. Confirm that all configured rules are displayed.

Example:

- AWS Core Rule Set
- Amazon IP Reputation List

- Anonymous IP List
- SQL Injection Protection
- Known Bad Inputs
- Rate Limit Rule (if configured)
- IP Address Rule (if configured)
- Country Rule (if configured)

Step 14: Monitor Traffic

Objective

View the traffic monitored by AWS WAF.

Procedure

1. Open the **Traffic Overview** tab.
2. Observe the following metrics:
 - Allowed Requests
 - Blocked Requests
 - Counted Requests

Expected Result

Traffic statistics are displayed for the Protection Pack.

Step 15: Monitor Using CloudWatch (Optional)

Objective: Monitor AWS WAF metrics using Amazon CloudWatch.

Procedure

1. Open the AWS Console.
2. Search for **CloudWatch**.
3. Navigate to:

Metrics



WAFV2

4. Review the available metrics:
 - AllowedRequests
 - BlockedRequests
 - CountedRequests

Step 16: Delete the Protection Pack (Cleanup)

Objective: Delete the Protection Pack to avoid unnecessary AWS charges after testing.

Procedure

1. Open **AWS WAF**.
2. Navigate to **Protection Packs (Web ACLs)**.
3. Select the created Protection Pack.
4. Remove the associated Application Load Balancer if required.
5. Click **Delete**.
6. Confirm the deletion.

Expected Result

The Protection Pack is removed successfully.

AWS Systems Manager Parameter Store

Objective: The objective of this implementation is to learn how to use AWS Systems Manager Parameter Store to centrally store, manage, and retrieve application configuration data and sensitive information.

This hands-on exercise demonstrates the creation, modification, retrieval, and deletion of parameters using both the AWS Management Console and AWS CLI.

Prerequisites

Before starting the implementation, ensure the following requirements are met.

- AWS Account

- IAM User with AdministratorAccess or Systems Manager permissions
- Internet Connection
- AWS CLI installed (optional for CLI practice)
- Selected AWS Region: **US East (N. Virginia)**

Step 1: Log in to the AWS Management Console

Purpose

Access the AWS Management Console to begin the implementation.

Procedure

1. Open your preferred web browser.
2. Navigate to the AWS Management Console.
3. Enter your AWS credentials.
4. Click **Sign In**.

Step 2: Open AWS Systems Manager

Purpose

Navigate to AWS Systems Manager.

Procedure

1. In the AWS search bar, type **Systems Manager**.
2. Select **AWS Systems Manager** from the search results.

Step 3: Open Parameter Store

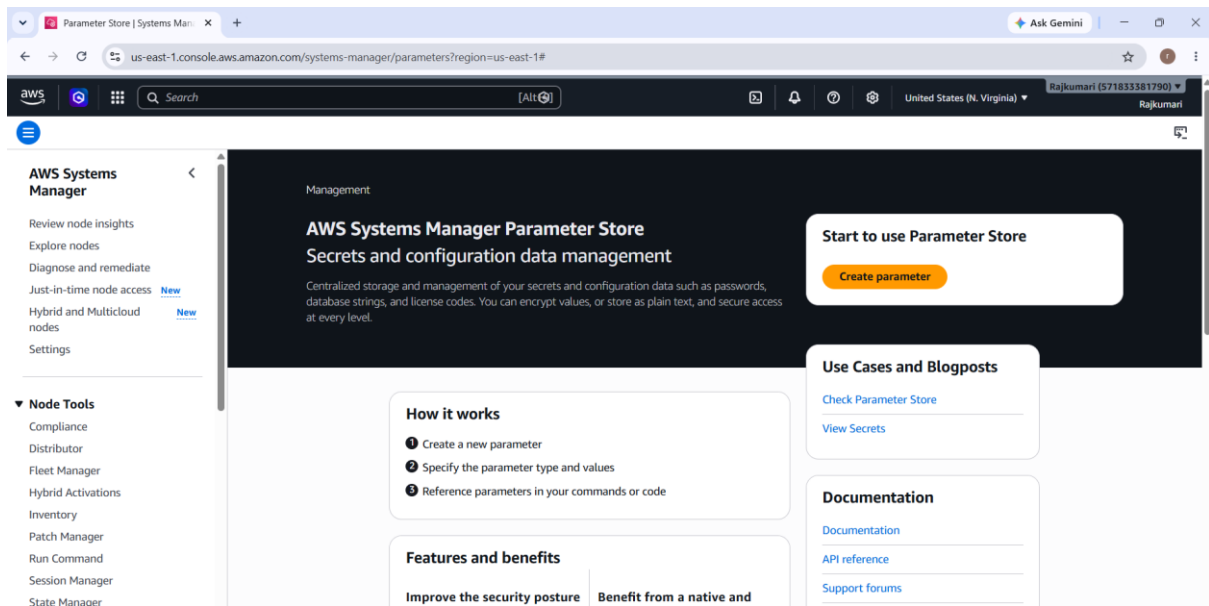
Purpose

Navigate to the Parameter Store service.

Procedure

1. Expand **Application Management**.
2. Select **Parameter Store**.

Expected Result



Step 4: Create a String Parameter

Purpose

Create a standard configuration parameter.

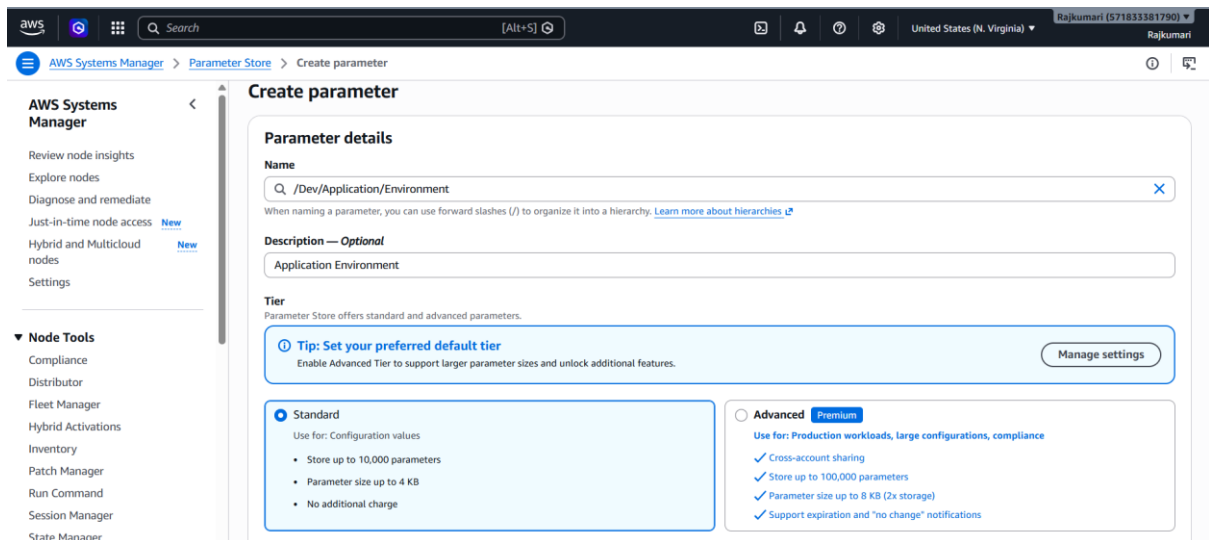
Procedure

Click **Create Parameter**.

Provide the following values.

Field	Value
Name	/Dev/Application/Environment
Description	Application Environment
Tier	Standard
Type	String
Data Type	text
Value	Production

Click **Create Parameter**.



Step 5: Verify the Parameter

Purpose: Verify the parameter details.

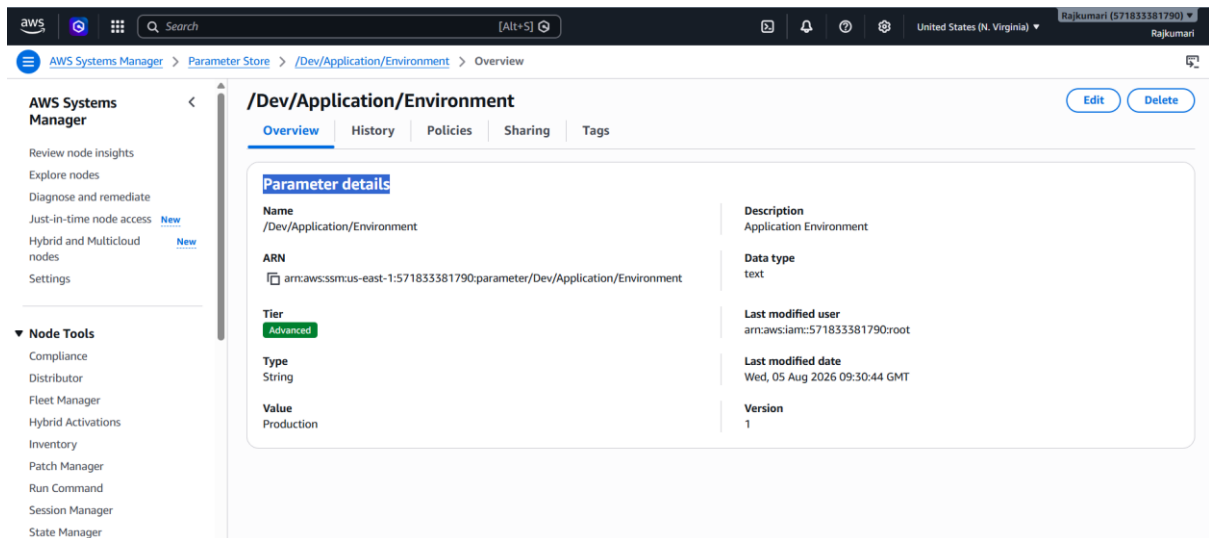
Procedure: Click the newly created parameter.

Verify:

- Name
- ARN
- Version
- Last Modified Date
- Type
- Tier
- Value

Expected Result

Version should display **Version 1**.



Step 6: Create a SecureString Parameter

Purpose

Store sensitive data securely.

Procedure

Create another parameter with the following values.

Field	Value
Name	/Dev/Database/Password
Type	SecureString
Tier	Standard
KMS Key	aws/ssm
Value	Welcome@123

Click **Create Parameter**.

AWS Systems Manager > **Parameter Store** > Create parameter

Create parameter

Parameter details

Name

When naming a parameter, you can use forward slashes (/) to organize it into a hierarchy. [Learn more about hierarchies](#)

Description — Optional

Tier
 Parameter Store offers standard and advanced parameters.

Tip: Set your preferred default tier
 Enable Advanced Tier to support larger parameter sizes and unlock additional features. [Manage settings](#)

☒ **Standard**
 Use for: Configuration values

- Store up to 10,000 parameters
- Parameter size up to 4 KB
- No additional charge

☐ **Advanced** Premium
 Use for: Production workloads, large configurations, compliance

- ✓ Cross-account sharing
- ✓ Store up to 100,000 parameters
- ✓ Parameter size up to 8 KB (2x storage)
- ✓ Support expiration and "no change" notifications

AWS Systems Manager > **Parameter Store** > Create parameter

Type

☐ String
Any string value.

☐ StringList
Separate strings using commas.

☒ **SecureString**
Encrypt sensitive data using KMS keys from your account or another account.

Use SecureString for configuration values that require encryption such as service endpoints and account identifiers.
 For secrets such as database credentials, API keys, or tokens, we recommend AWS Secrets Manager, which provides purpose built security controls including automatic rotation and cross-region replication. [Learn more](#)

KMS key source - [Learn more](#)

☒ My current account
Use the default KMS key for this account or specify a customer-managed key for this account.

☐ Another account
Use a KMS key from another account

KMS Key ID

You have selected the default AWS managed key
 AWS managed keys cannot be shared with other AWS accounts, and all users in this AWS account and Region have access to the key. Use a customer managed key for sharing and access control. [Learn more](#)

AWS Systems Manager > **Parameter Store**

Create parameter request succeeded! [View details](#)

Parameter Store

[My parameters](#) | [Public parameters](#) | [Settings](#)

Ready to scale? Enable higher throughput to handle more API calls - [Manage Settings](#) to increase TPS. [Manage settings](#)

My parameters [View details](#) [Edit](#) [Delete](#) [Create parameter](#)

☐	Name	Tier	Type	Last modified
☐	/Dev/Application/Environment	Advanced	String	Wed, 05 Aug 2026 09:30:44 GMT
☐	/Dev/Database/Password	Standard	SecureString	Wed, 05 Aug 2026 09:36:45 GMT

Step 7: Update a Parameter

Purpose

Modify an existing parameter value.

Procedure

Open

/Dev/Application/Environment

Click **Edit**.

Change

Production

to

Development

Save the changes.

Expected Result

The parameter version increases from Version 1 to Version 2.

The screenshot shows the AWS Systems Manager console interface. At the top, there's a navigation bar with the AWS logo, a search icon, and a user profile 'Rajkumari (571833381790)'. Below the navigation bar, the breadcrumb trail reads 'AWS Systems Manager > ... > /Dev/Application/Environment > Edit para...'. The main content area is divided into two columns. The left column contains a list of bullet points: 'Store up to 10,000 parameters', 'Parameter size up to 4 KB', and 'No additional charge'. The right column contains a list of checkmarks: 'Cross-account sharing', 'Store up to 100,000 parameters', 'Parameter size up to 8 KB (2x storage)', and 'Support expiration and "no change" notifications'. Below these columns, the 'Type' is set to 'String', the 'Data type' is set to 'text', and the 'Value' is 'Development'. A note at the bottom of the value field states 'Maximum length 8192 characters.' Below the main content area, there's a section titled 'Parameter policies — Optional' with a sub-section 'Parameter expiration' that explains how long the parameter is available in Parameter Store.

aws

United States (N. Virg)

Rajkumari (571833381790)

Rajkumari

AWS Systems Manager > ... > /Dev/Application/Environment > Edit para...

Use for: Configuration values

- Store up to 10,000 parameters
- Parameter size up to 4 KB
- No additional charge

Use for: Production workloads, large configurations, compliance

- ✓ Cross-account sharing
- ✓ Store up to 100,000 parameters
- ✓ Parameter size up to 8 KB (2x storage)
- ✓ Support expiration and "no change" notifications

Type

String

Data type

text

Value

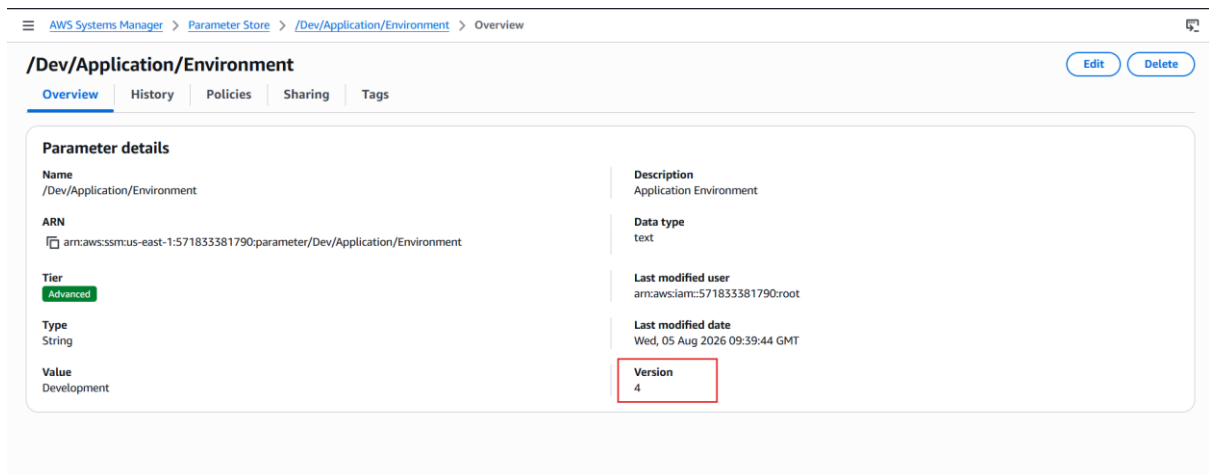
Development

Maximum length 8192 characters.

Parameter policies — *Optional*

Parameter expiration

Specify how long the parameter is available in Parameter Store, as either a point-in-time or lifetime. The parameter is deleted after the specified date.



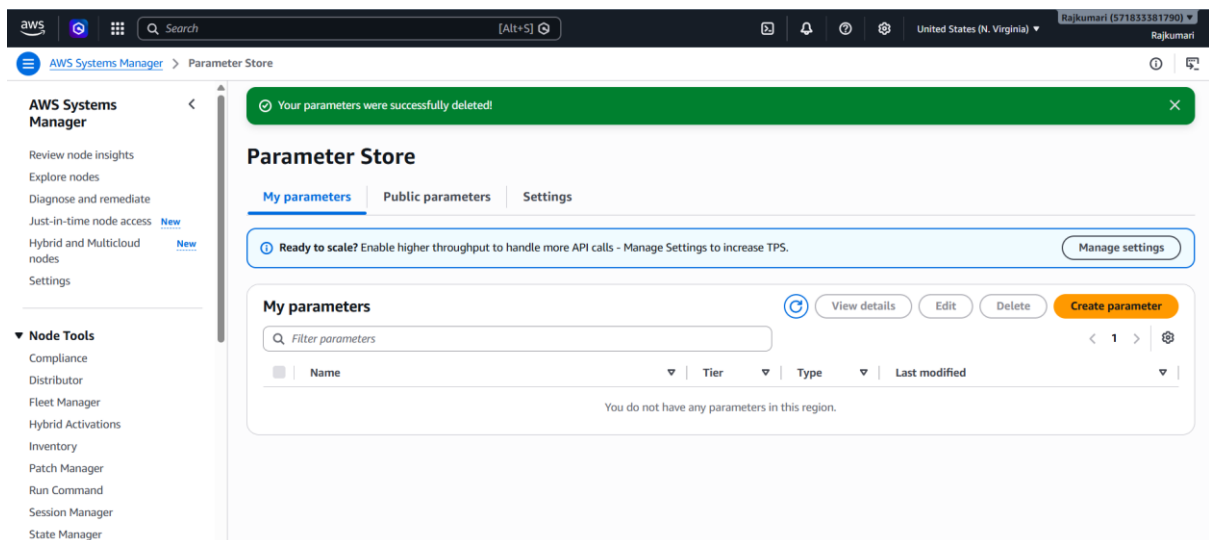
Step 9: Delete Parameters

If your assignment requires cleanup, delete the parameters after verification.

Delete:

- /Dev/Application/Environment
- /Dev/Database/Password

Otherwise, you can keep them for future practice.



Step 10: Retrieve Parameters Using AWS CLI (Optional)

Retrieve the String parameter:

```
aws ssm get-parameter --name "/Dev/Application/Environment"
```

Retrieve the SecureString parameter:

```
aws ssm get-parameter \  
  
--name "/Dev/Database/Password" \  
  
--with-decryption
```

Expected Result:

The parameter values are returned in JSON format.

```
ec2-user@ip-172-31-0-231:~  
[ec2-user@ip-172-31-0-231 ~]$ aws configure  
AWS Access Key ID [None]: AKIAWKI7M6OPPZD327GJ  
AWS Secret Access Key [None]: TRwB0Jvw7YiRnQ2eaLXIR/P4zouRBDGHTNWg]pcj  
Default region name [None]: us-east-1  
Default output format [None]: json  
[ec2-user@ip-172-31-0-231 ~]$ aws --version  
aws-cli/2.33.15 Python/3.9.25 Linux/6.18.38-76.139.amzn2023.x86_64 source/x86_64  
.amzn.2023  
[ec2-user@ip-172-31-0-231 ~]$ aws ssm get-parameter --name "/Dev/Application/Env  
ironment"  
{  
  "Parameter": {  
    "Name": "/Dev/Application/Environment",  
    "Type": "String",  
    "Value": "Development",  
    "Version": 4,  
    "LastModifiedDate": "2026-08-05T09:39:44.167000+00:00",  
    "ARN": "arn:aws:ssm:us-east-1:571833381790:parameter/Dev/Application/Env  
ironment",  
    "DataType": "text"  
  }  
}  
[ec2-user@ip-172-31-0-231 ~]$ aws ssm get-parameter \  
--name "/Dev/Database/Password" \  
--with-decryption  
{  
  "Parameter": {  
    "Name": "/Dev/Database/Password",  
    "Type": "SecureString",  
    "Value": "rajkumari",  
    "Version": 1,  
    "LastModifiedDate": "2026-08-05T09:36:45.126000+00:00",  
    "ARN": "arn:aws:ssm:us-east-1:571833381790:parameter/Dev/Database/Passwo  
rd",  
    "DataType": "text"  
  }  
}  
[ec2-user@ip-172-31-0-231 ~]$ |
```